

Vendor Hosting & Data Map

Radiantlyk Aesthetic — San Jose, CA

Prepared July 04, 2026 · Confidential — internal compliance reference

Purpose

This document maps every third-party vendor that stores, processes, or transmits Radiantlyk Aesthetic business or client data. For each vendor: what data lives there, hosting region, encryption, retention, subprocessors, access controls, and BAA / HIPAA status. Use this as the source of truth for HIPAA §164.308(b), §164.314(a), and OCR audit response.

Vendor Summary Matrix

Vendor	Role	Data Class	Region	BAA
Lovable Cloud (Supabase)	App DB, auth, storage, edge fns	PHI + PII	US-East (AWS us-east-1)	Enterprise req.
GoHighLevel	CRM, SMS, email, reminders	PHI + PII	US (AWS us-east)	Add-on \$297/mo
Stripe	Card processing, terminals	PCI (card), PII	US (multi-AZ)	N/A (PCI-DSS L1)
Resend	Transactional email (via Lovable)	PII (email, name)	US (AWS us-east-1)	Available
Twilio	SMS (via GHL)	PII + limited PHI	US	Available
Google (OAuth/Calendar)	Staff calendar sync	Staff PII, appt titles	US multi-region	Workspace BAA
Cloudflare	DNS, CDN, WAF	Metadata only	Global edge	N/A
Lovable (hosting)	Frontend hosting, preview	Public assets	Global CDN	Enterprise req.

Legend — Data Class: PHI = Protected Health Info (names + treatment/appt/clinical). PII = Personally Identifiable Info (name, phone, email). PCI = Payment Card Info.

Lovable Cloud (Supabase-managed Postgres)

Role	Primary application backend: Postgres database, authentication, file storage (photos, PDFs), edge functions.
Data stored	Client profiles, appointments, clinical notes (neurotoxin/filler/energy/wellness), consent signatures, intake forms, product lots, sales, PROMs, adverse events, staff records, PHI access logs.
Hosting region	AWS us-east-1 (N. Virginia) — Supabase managed.
Encryption	At rest: AES-256 (AWS EBS). In transit: TLS 1.2+. Storage bucket objects encrypted.
Access control	Row Level Security on 110+ tables. Role-based via user_roles table + has_role() definer function. Service-role key restricted to edge functions.
Auth	Supabase Auth (email + Google OAuth). MFA available.
Retention	Application-defined. PHI deletion requests handled via phi_deletion_requests table workflow. Clinical records retained per CA §1300.68 (7 yrs adult / until 21 minor).
Audit logging	phi_access_log, appointment_audit_log, clinical_audit_log, consent_pdf_audit, consent_validation_log.
Subprocessors	AWS (compute/storage), Supabase Inc.
BAA / HIPAA	Not covered on current Lovable plan. Requires Lovable Enterprise (sales@lovable.dev). Business \$279/mo does not include BAA.
Action required	Contact Lovable Enterprise for signed BAA before storing PHI at scale.

GoHighLevel (GHL)

Role	CRM, two-way SMS, marketing email, appointment reminders, pipeline automations.
Data stored	Client name, phone, email, appointment date/time/service, reminder message content, tags, notes synced from app.
Hosting region	AWS US (primarily us-east).
Encryption	TLS 1.2+ in transit; AES-256 at rest.
Access control	Sub-account isolation, agency-level admin, 2FA available (enable for all staff).
Retention	Indefinite until manually deleted. Configure per HIPAA add-on data retention policy after BAA.
Audit logging	Available only under HIPAA Compliance add-on (audit trail, access logs, session tracking).
Subprocessors	Twilio (SMS), Mailgun/SendGrid (email), AWS.
BAA / HIPAA	Current plan: Agency Unlimited \$279/mo — NO BAA. Requires HIPAA Compliance add-on \$297/mo (total ~\$576/mo) for signed BAA, ePHI encryption, MFA enforcement, restricted integrations.
Action required	Purchase HIPAA add-on before sending appointment SMS/email containing client name + service details.

Stripe

Role	Card processing (in-app checkout + Stripe Terminal readers), no-show fee capture, subscription/payment plans.
Data stored	Card tokens (never raw PAN on our systems), payer name, billing address, transaction history, terminal reader IDs.
Hosting region	US multi-region (Stripe managed).
Encryption	PCI-DSS Level 1 certified. TLS 1.2+, HSM-backed key mgmt.
Access control	Restricted API keys stored as Cloud secrets, dashboard SSO + 2FA.
Retention	Financial records 7 yrs (IRS). Cardholder tokens retained for repeat charges/no-show fees.
Audit logging	Stripe Dashboard event log; webhook events mirrored to webhook_events_processed table.
Subprocessors	AWS, Google Cloud.
BAA / HIPAA	Not required — payment data is not PHI when limited to billing. Do not put diagnosis/treatment detail in Stripe metadata.
Action required	Audit Stripe product/metadata fields — ensure no clinical descriptors leak into line items.

Resend (Lovable Emails)

Role	Transactional email delivery: appointment confirmations, consent PDFs, receipts, auth emails. Sent via Lovable's process-email-queue edge function.
Data stored	Recipient email, subject, rendered HTML (may include appt time + service name), send status.
Hosting region	AWS us-east-1.
Encryption	TLS in transit, encrypted at rest.
Access control	API key held in Lovable Cloud Vault; not exposed to browser.
Retention	Send logs 30 days at Resend; email_send_log table retains indefinitely in our DB.
Audit logging	email_send_log, suppressed_emails, email_unsubscribe_tokens.
Subprocessors	AWS.
BAA / HIPAA	Resend offers BAA on paid plan. Coverage flows through Lovable Enterprise BAA when signed.
Action required	Verify BAA scope covers Resend when Lovable Enterprise is signed; otherwise strip service names from email subjects.

Twilio (via GoHighLevel)

Role	SMS carrier for all appointment reminders, two-way client texting, no-show notifications.
Data stored	Sender/recipient phone numbers, message body, delivery status, timestamps.
Hosting region	US (Twilio managed multi-region).
Encryption	TLS 1.2+ in transit; AES-256 at rest.
Access control	Managed indirectly through GHL sub-account; no direct Twilio console access.
Retention	Twilio: message body 13 months (configurable). GHL mirrors indefinitely.
Audit logging	GHL conversation log; app-side sms_send_log, sms_messages, ghl_reminder_log.
Subprocessors	AWS, US wireless carriers.
BAA / HIPAA	Twilio BAA is only valid when signed directly with Twilio or passed through GHL HIPAA add-on. Standard GHL plan does not extend Twilio BAA.
Action required	Same as GHL — HIPAA add-on required before any PHI-adjacent SMS.

Google (Workspace / OAuth / Calendar)

Role	Staff Google Calendar two-way sync for appointments (<code>staff_google_oauth</code> table), Google sign-in for staff/clients.
Data stored	Staff email, OAuth refresh tokens, calendar event titles (appt type + client first name), start/end times.
Hosting region	Google multi-region.
Encryption	TLS 1.2+ in transit; encrypted at rest with Google-managed keys.
Access control	OAuth refresh tokens stored encrypted in <code>staff_google_oauth</code> (RLS: staff self-access only). Scopes limited to <code>calendar.events</code> .
Retention	Tokens rotated per Google policy; revoked on staff offboarding.
Audit logging	<code>staff_google_oauth</code> <code>updated_at</code> + app-side event log via <code>appointment_staff_calendar_events</code> .
Subprocessors	Google Cloud.
BAA / HIPAA	Google Workspace BAA available (Business Plus+). Requires org admin acceptance in Workspace admin console.
Action required	Ensure Workspace BAA is accepted; keep calendar event titles minimal (no diagnosis).

Cloudflare

Role	DNS (<code>bookrka.com</code> , <code>rkabook.lovable.app</code>), CDN, TLS termination at edge, WAF/bot protection.
Data stored	Request metadata: IPs, user agents, timings. No app payload cached for authenticated routes.
Hosting region	Global edge (300+ POPs).
Encryption	TLS 1.3 termination; origin re-encryption to Lovable hosting.
Access control	Cloudflare dashboard SSO + 2FA.
Retention	Analytics 30 days; logs per plan tier.
Audit logging	Cloudflare audit log.
Subprocessors	N/A (Cloudflare-owned network).
BAA / HIPAA	Cloudflare BAA available on Enterprise plan; typically not required as no PHI traverses cacheable routes.
Action required	Confirm no PHI in URL query strings (which get logged).

Lovable (Frontend Hosting)

Role	Serves the React SPA at <code>rkabook.lovable.app</code> + custom domain <code>bookrka.com</code> .
Data stored	Static assets only. No client data resides in the hosting layer.
Hosting region	Global CDN.
Encryption	TLS 1.3 in transit.
Access control	Deploy access limited to workspace members with editor role.
Retention	Build artifacts retained per Lovable platform policy.
Audit logging	Lovable deployment history.
Subprocessors	AWS, Cloudflare.
BAA / HIPAA	Rolled into Lovable Enterprise BAA when signed.
Action required	No PHI in bundle. Verified — client data fetched at runtime from Cloud.

Data Flow Summary

Below is the end-to-end path of a client appointment from booking to reminder to check-in, showing which vendor holds the data at each step.

Step	System of record	Vendor(s) touched	Data class
1. Client books on bookrka.com	Cloud DB (appointments)	Lovable hosting → Cloud → GHl sync	PHI + PII
2. Confirmation email sent	email_send_log	Cloud fn → Resend	PII (+ service name)
3. Card on file captured	Stripe	Stripe (token) → Cloud (customer_id)	PCI
4. Reminder SMS 48h/24h	ghl_reminder_log	GHl → Twilio → carrier	PII + limited PHI
5. Intake form completed	client_intake_submissions	Cloud DB	PHI
6. Staff calendar sync	appointment_staff_calendar_events	Cloud → Google Calendar	Staff PII + appt
7. Visit + clinical note	clinical_notes + subtables	Cloud DB (RLS)	PHI
8. Consent PDF signed	consent_signatures + storage	Cloud storage → Resend (copy)	PHI
9. Payment captured	sales, sale_items	Stripe → Cloud webhook	PCI + PII
10. Post-op check-in	postop_checkins, prom_responses	Cloud DB, GHl SMS	PHI

Compliance Gaps — Action Items

#	Item	Action
1	Lovable Enterprise BAA	Business \$279/mo does not include BAA. Contact sales@lovable.dev to price Enterprise + BAA covering Cloud, Resend, hosting.
2	GoHighLevel HIPAA add-on	Add \$297/mo HIPAA Compliance add-on to existing \$279/mo Agency Unlimited plan. Request signed BAA + enable MFA for all sub-account users.
3	Google Workspace BAA	Confirm Workspace admin has accepted BAA (Admin console → Account settings → Legal & Compliance).
4	Stripe metadata audit	Review Stripe product names and metadata — remove any clinical descriptors; keep to service SKU only.
5	Cloudflare URL hygiene	Ensure no query strings carry client identifiers or PHI (currently compliant — verify on next code review).

— End of report —